

INC Ransom Threat Profile

Date: February 26, 2026

INC Ransom is a relatively new but highly aggressive Ransomware-as-a-Service (RaaS) group that first emerged in **July/August 2023**. Despite its short history, it has quickly gained notoriety for targeting high-profile organizations across various sectors, including healthcare, education, and government.

Here is a detailed description of the group's operations, tactics, and targets:

1. Operational Model

INC Ransom operates as a **Ransomware-as-a-Service (RaaS)** provider. This means the core developers maintain the ransomware code and the "leak site," while "affiliates" carry out the actual attacks and split the profits with the developers.

2. Extortion Tactics (Double Extortion)

Like most modern ransomware groups, INC Ransom employs **double extortion**:

- **Encryption:** They lock the victim's files, making systems unusable.
- **Data Theft (Exfiltration):** Before encrypting the files, they steal sensitive data. They threaten to publish this data on their public "INC Ransom Blog" (a leak site hosted on the dark web) if the ransom is not paid.
- **Pressure:** They often provide victims with a "proof of theft" to pressure them into negotiations.

3. Technical Tactics, Techniques, and Procedures (TTPs)

INC Ransom is known for being technically versatile, with versions of their malware written for both **Windows** and **Linux (specifically VMware ESXi environments)**.

- **Initial Access:** They primarily gain entry through:
 - **Spear-phishing** emails.
 - Exploiting **vulnerabilities** in outward-facing software (e.g., CVE-2023-3519 in Citrix NetScaler).
 - Compromised **Remote Desktop Protocol (RDP)** credentials.
- **Lateral Movement & Discovery:** Once inside, they use common tools like **Advanced IP Scanner**, **NetScan**, and **PowerShell** to map the network. They often use **Psexec** or **AnyDesk** for remote control.
- **Exfiltration:** They typically use **Rclone** or **Mega.nz** tools to move stolen data to their own servers before triggering the encryption process.
- **Encryption:** The ransomware uses a sophisticated combination of AES and RSA encryption. It often terminates processes related to security software and backups to ensure the encryption is successful.

4. Target Demographics

INC Ransom appears to be **opportunistic** rather than politically motivated, but they lean heavily toward Western targets. Their primary sectors include:

- **Healthcare:** They have targeted hospitals and clinics, where downtime can be life-threatening.

- **Education:** Several US school districts have been listed on their leak site.
- **Government & Public Sector:** They have targeted local government entities.
- **Industrial & Manufacturing:** Large-scale commercial enterprises.

5. Notable Attacks

- **NHS Scotland (NHS Dumfries and Galloway):** In early 2024, the group claimed a massive data breach involving clinical data of patients, eventually leaking thousands of sensitive documents after the ransom wasn't paid.
- **Xerox Business Solutions:** In late 2023, the group claimed to have breached a subsidiary of Xerox, leaking data to prove their access.
- **Poly (formerly Polycom):** The group listed the communications giant on their leak site in 2024.

6. Communication Style

The group maintains a somewhat "professional" facade. Their ransom notes are often concise, directing victims to a unique Tor-based portal for negotiations. Unlike some "hactivist" groups, INC Ransom is purely financially motivated and avoids public political alignments.

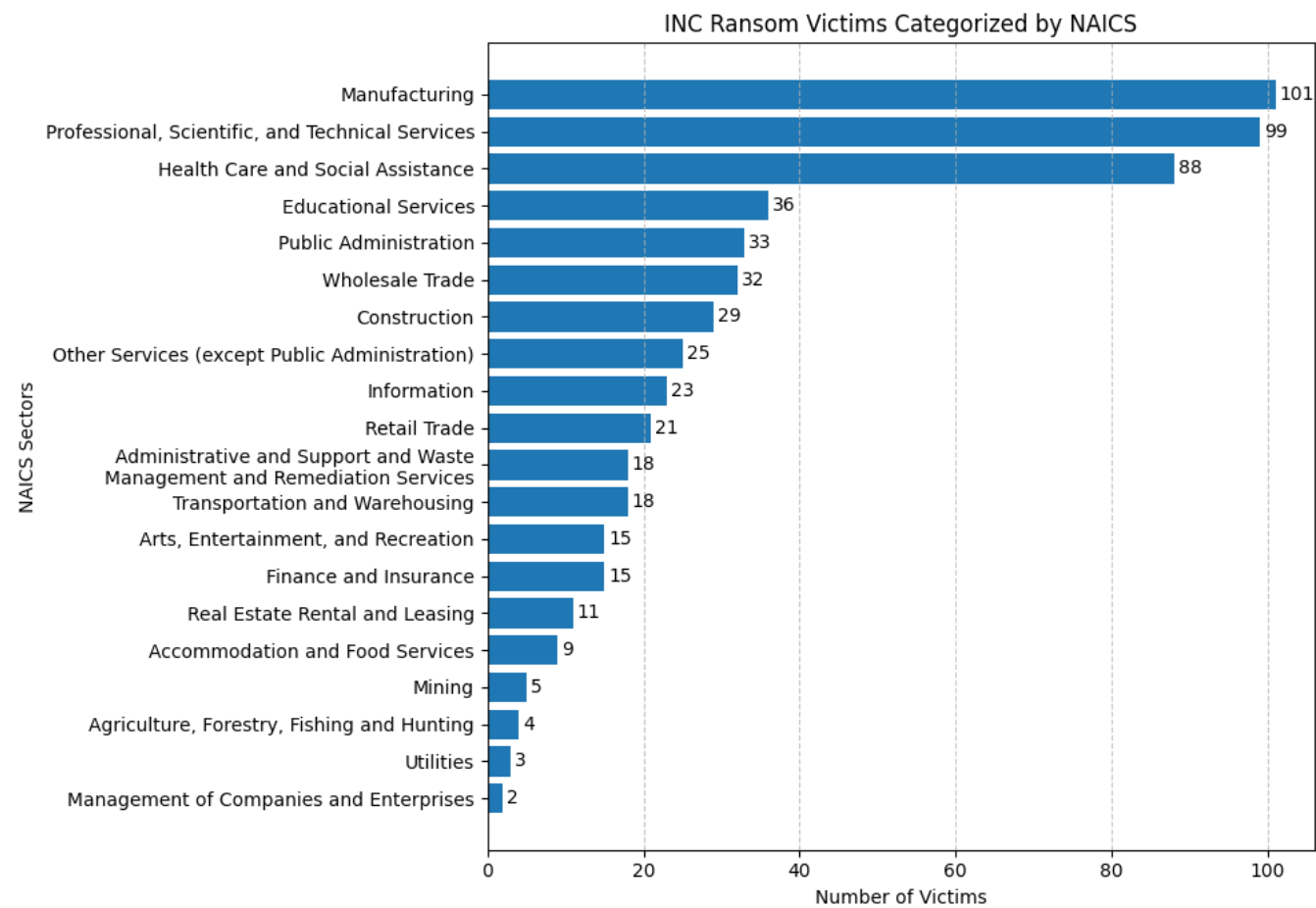
7. Defense and Mitigation

To defend against INC Ransom, cybersecurity agencies (like the FBI and CISA) recommend:

- **Patching vulnerabilities:** Especially in VPNs and remote access tools (Citrix, VMware).
- **Multi-Factor Authentication (MFA):** Enforcing MFA on all remote access points.
- **Offline Backups:** Maintaining encrypted, offline backups that cannot be reached by the ransomware.
- **Endpoint Detection (EDR):** Using tools that monitor for the use of Living-off-the-Land (LotL) binaries like PowerShell and Rclone.

Summary: INC Ransom is a "top-tier" emerging threat. Their ability to target both Windows and Linux environments and their willingness to attack critical infrastructure like healthcare makes them a significant concern for global cybersecurity.

Industry Targeting



Malware

Name	
0	ransomware
1	INC Ransomware

Indicators Valid Until May 05, 2026 04:10 AM UTC

Type	Name
0	Domain-Name finance.com

Indicators Valid Until November 09, 2026 12:24 AM UTC

Type	Name
0	SHA-256 1663d98c259001f1b03f82d0c5bee7cfd3c7623ccb83759c994f9ab845939665
1	SHA-256 d2263684cfb35bae31de108f5edebdf35cccf21eb8e315a28b39952fae50b3a9
2	SHA-256 d033d0e44b4f4be7ca3b8d063ea95699d1c894896ef912bf52c2296bc73f8838

Attack Patterns

	Name	MITRE ID
0	Windows Command Shell	T1059.003
1	Match Legitimate Resource Name or Location	T1036.005
2	Remote Access Tools	T1219
3	Indicator Removal	T1070
4	Network Service Discovery	T1046
5	Account Discovery	T1087
6	Lateral Tool Transfer	T1570
7	Data Staged	T1074
8	Exfiltration Over C2 Channel	T1041
9	File Deletion	T1070.004
10	Remote Services	T1021
11	Archive via Utility	T1560.001
12	Archive Collected Data	T1560
13	Impair Defenses	T1562
14	Valid Accounts	T1078
15	Windows Management Instrumentation	T1047
16	Data from Local System	T1005
17	System Information Discovery	T1082
18	Phishing	T1566
19	Masquerading	T1036
20	System Network Connections Discovery	T1049
21	Exploit Public-Facing Application	T1190
22	Transfer Data to Cloud Account	T1537
23	Obtain Capabilities	T1588
24	Remote Desktop Protocol	T1021.001
25	Data Encrypted for Impact	T1486
26	Command and Scripting Interpreter	T1059
27	Service Execution	T1569.002
28	Domain Account	T1087.002
29	System Services	T1569

	Name	MITRE ID
30	Application Layer Protocol	T1071
31	Permission Groups Discovery	T1069
32	Domain Groups	T1069.002
33	File and Directory Discovery	T1083
34	Ingress Tool Transfer	T1105
35	Financial Theft	T1657
36	Tool	T1588.002
37	Network Share Discovery	T1135
38	Disable or Modify Tools	T1562.001
39	Exfiltration Over Alternative Protocol	T1048

Appendix

Attack Pattern Descriptions

Windows Command Shell - [T1059.003](#)

Adversaries may abuse the Windows command shell for execution. The Windows command shell ([cmd](#)) is the primary command prompt on Windows systems. The Windows command prompt can be used to control almost any aspect of a system, with various permission levels required for different subsets of commands. The command prompt can be invoked remotely via [Remote Services](#) such as [SSH](#).(Citation: SSH in Windows)

Batch files (ex: .bat or .cmd) also provide the shell with a list of sequential commands to run, as well as normal scripting operations such as conditionals and loops. Common uses of batch files include long or repetitive tasks, or the need to run the same set of commands on multiple systems.

Adversaries may leverage [cmd](#) to execute various commands and payloads. Common uses include [cmd](#) to execute a single command, or abusing [cmd](#) interactively with input and output forwarded over a command and control channel.

Match Legitimate Resource Name or Location - [T1036.005](#)

Adversaries may match or approximate the name or location of legitimate files, Registry keys, or other resources when naming/placing them. This is done for the sake of evading defenses and observation.

This may be done by placing an executable in a commonly trusted directory (ex: under System32) or giving it the name of a legitimate, trusted program (ex: [svchost.exe](#)). Alternatively, a Windows Registry key may be given a close approximation to a key used by a legitimate program. In containerized environments, a threat actor may create a resource in a trusted namespace or one that matches the naming convention of a container pod or cluster.(Citation: Aquasec Kubernetes Backdoor 2023)

Remote Access Tools - [T1219](#)

An adversary may use legitimate remote access tools to establish an interactive command and control channel within a network. Remote access tools create a session between two trusted hosts through a graphical interface, a command line interaction, a protocol tunnel via development or management software, or hardware-level access such as KVM (Keyboard, Video, Mouse) over IP solutions. Desktop support software (usually graphical interface) and remote management software (typically command line interface) allow a user to control a computer remotely as if they are a local user inheriting the user or software permissions. This software is commonly used for troubleshooting, software installation, and system management.(Citation: Symantec Living off the Land)(Citation: CrowdStrike 2015 Global Threat Report)(Citation: CrySyS Blog TeamSpy) Adversaries may similarly abuse response features included in EDR and other defensive tools that enable remote access.

Remote access tools may be installed and used post-compromise as an alternate communications channel for redundant access or to establish an interactive remote desktop session with the target system. It may also be used as a malware component to establish a reverse connection or back-connect to a service or adversary-controlled system.

Installation of many remote access tools may also include persistence (e.g., the software's installation routine creates a [Windows Service](#)). Remote access modules/features may also exist as part of otherwise existing software (e.g., Google Chrome's Remote Desktop).(Citation: Google Chrome Remote Desktop)(Citation: Chrome Remote Desktop)

Indicator Removal - T1070

Adversaries may delete or modify artifacts generated within systems to remove evidence of their presence or hinder defenses. Various artifacts may be created by an adversary or something that can be attributed to an adversary's actions. Typically these artifacts are used as defensive indicators related to monitored events, such as strings from downloaded files, logs that are generated from user actions, and other data analyzed by defenders. Location, format, and type of artifact (such as command or login history) are often specific to each platform.

Removal of these indicators may interfere with event collection, reporting, or other processes used to detect intrusion activity. This may compromise the integrity of security solutions by causing notable events to go unreported. This activity may also impede forensic analysis and incident response, due to lack of sufficient data to determine what occurred.

Network Service Discovery - T1046

Adversaries may attempt to get a listing of services running on remote hosts and local network infrastructure devices, including those that may be vulnerable to remote software exploitation. Common methods to acquire this information include port, vulnerability, and/or wordlist scans using tools that are brought onto a system. (Citation: CISA AR21-126A FIVEHANDS May 2021)

Within cloud environments, adversaries may attempt to discover services running on other cloud hosts. Additionally, if the cloud environment is connected to a on-premises environment, adversaries may be able to identify services running on non-cloud systems as well.

Within macOS environments, adversaries may use the native Bonjour application to discover services running on other macOS hosts within a network. The Bonjour mDNSResponder daemon automatically registers and advertises a host's registered services on the network. For example, adversaries can use a mDNS query (such

as `dns-sd -B _ssh._tcp .`) to find other systems broadcasting the ssh service.(Citation: apple doco bonjour description)(Citation: macOS APT Activity Bradley)

Account Discovery - T1087

Adversaries may attempt to get a listing of valid accounts, usernames, or email addresses on a system or within a compromised environment. This information can help adversaries determine which accounts exist, which can aid in follow-on behavior such as brute-forcing, spear-phishing attacks, or account takeovers (e.g., [Valid Accounts](#)).

Adversaries may use several methods to enumerate accounts, including abuse of existing tools, built-in commands, and potential misconfigurations that leak account names and roles or permissions in the targeted environment.

For examples, cloud environments typically provide easily accessible interfaces to obtain user lists.(Citation: AWS List Users)(Citation: Google Cloud - IAM Service Accounts List API) On hosts, adversaries can use default [PowerShell](#) and other command line functionality to identify accounts. Information about email addresses and accounts may also be extracted by searching an infected system's files.

Lateral Tool Transfer - T1570

Adversaries may transfer tools or other files between systems in a compromised environment. Once brought into the victim environment (i.e., [Ingress Tool Transfer](#)) files may then be copied from one system to another to stage adversary tools or other files over the course of an operation.

Adversaries may copy files between internal victim systems to support lateral movement using inherent file sharing protocols such as file sharing over [SMB/Windows Admin Shares](#) to connected network shares or with authenticated connections via [Remote Desktop Protocol](#).(Citation: Unit42 LockerGoga 2019)

Files can also be transferred using native or otherwise present tools on the victim system, such as scp, rsync, curl, sftp, and [ftp](#). In some cases, adversaries may be able to leverage [Web Services](#) such as Dropbox or OneDrive to copy files from one machine to another via shared, automatically synced folders.(Citation: Dropbox Malware Sync)

Data Staged - T1074

Adversaries may stage collected data in a central location or directory prior to Exfiltration. Data may be kept in separate files or combined into one file through techniques such as [Archive Collected Data](#). Interactive command shells may be used, and common functionality within `cmd` and `bash` may be used to copy data into a staging location.(Citation: PWC Cloud Hopper April 2017)

In cloud environments, adversaries may stage data within a particular instance or virtual machine before exfiltration. An adversary may [Create Cloud Instance](#) and stage data in that instance.(Citation: Mandiant M-Trends 2020)

Adversaries may choose to stage data from a victim network in a centralized location prior to Exfiltration to minimize the number of connections made to their C2 server and better evade detection.

Exfiltration Over C2 Channel - T1041

Adversaries may steal data by exfiltrating it over an existing command and control channel. Stolen data is encoded into the normal communications channel using the same protocol as command and control communications.

File Deletion - T1070.004

Adversaries may delete files left behind by the actions of their intrusion activity. Malware, tools, or other non-native files dropped or created on a system by an adversary (ex: [Ingress Tool Transfer](#)) may leave traces to indicate to what was done within a network and how. Removal of these files can occur during an intrusion, or as part of a post-intrusion process to minimize the adversary's footprint.

There are tools available from the host operating system to perform cleanup, but adversaries may use other tools as well.(Citation: Microsoft SDelete July 2016) Examples of built-in [Command and Scripting Interpreter](#) functions include `del` on Windows, `rm` or `unlink` on Linux and macOS, and `rm` on ESXi.

Remote Services - T1021

Adversaries may use [Valid Accounts](#) to log into a service that accepts remote connections, such as telnet, SSH, and VNC. The adversary may then perform actions as the logged-on user.

In an enterprise environment, servers and workstations can be organized into domains. Domains provide centralized identity management, allowing users to login using one set of credentials across the entire network. If an adversary is able to obtain a set of valid domain credentials, they could login to many different machines using remote access protocols such as secure shell (SSH) or remote desktop protocol (RDP). (Citation: SSH Secure Shell)(Citation: TechNet Remote Desktop Services) They could also login to accessible SaaS or IaaS services, such as those that federate their identities to the domain, or management platforms for internal virtualization environments such as VMware vCenter.

Legitimate applications (such as [Software Deployment Tools](#) and other administrative programs) may utilize [Remote Services](#) to access remote hosts. For example, Apple Remote Desktop (ARD) on macOS is native software used for remote management. ARD leverages a blend of protocols, including [VNC](#) to send the screen and control buffers and [SSH](#) for secure file transfer.(Citation: Remote Management MDM macOS)(Citation: Kickstart Apple Remote Desktop commands)(Citation: Apple Remote Desktop Admin Guide 3.3) Adversaries can abuse applications such as ARD to gain remote code execution and perform lateral movement. In versions of macOS prior to 10.14, an adversary can escalate an SSH session to an ARD session which enables an adversary to accept TCC (Transparency, Consent, and Control) prompts without user interaction and gain access to data.(Citation: FireEye 2019 Apple Remote Desktop)(Citation: Lockboxx ARD 2019)(Citation: Kickstart Apple Remote Desktop commands)

Archive via Utility - T1560.001

Adversaries may use utilities to compress and/or encrypt collected data prior to exfiltration. Many utilities include functionalities to compress, encrypt, or otherwise package data into a format that is easier/more secure to transport.

Adversaries may abuse various utilities to compress or encrypt data before exfiltration. Some third party utilities may be preinstalled, such as `tar` on Linux and macOS or `zip` on Windows systems.

On Windows, [diantz](#) or [makecab](#) may be used to package collected files into a cabinet (.cab) file. [diantz](#) may also be used to download and compress files from remote locations (i.e. [Remote Data Staging](#)). (Citation: [diantz.exe_lolbas](#)) [xcopy](#) on Windows can copy files and directories with a variety of options. Additionally, adversaries may use [certutil](#) to Base64 encode collected data before exfiltration.

Adversaries may use also third party utilities, such as 7-Zip, WinRAR, and WinZip, to perform similar activities. (Citation: [7zip Homepage](#))(Citation: [WinRAR Homepage](#))(Citation: [WinZip Homepage](#))

Archive Collected Data - T1560

An adversary may compress and/or encrypt data that is collected prior to exfiltration. Compressing the data can help to obfuscate the collected data and minimize the amount of data sent over the network. (Citation: [DOJ GRU Indictment Jul 2018](#)) Encryption can be used to hide information that is being exfiltrated from detection or make exfiltration less conspicuous upon inspection by a defender.

Both compression and encryption are done prior to exfiltration, and can be performed using a utility, 3rd party library, or custom method.

Impair Defenses - T1562

Adversaries may maliciously modify components of a victim environment in order to hinder or disable defensive mechanisms. This not only involves impairing preventative defenses, such as firewalls and anti-virus, but also detection capabilities that defenders can use to audit activity and identify malicious behavior. This may also span both native defenses as well as supplemental capabilities installed by users and administrators.

Adversaries may also impair routine operations that contribute to defensive hygiene, such as blocking users from logging out, preventing a system from shutting down, or disabling or modifying the update process. Adversaries could also target event aggregation and analysis mechanisms, or otherwise disrupt these procedures by altering other system components. These restrictions can further enable malicious operations as well as the continued propagation of incidents. (Citation: [Google Cloud Mandiant UNC3886 2024](#))(Citation: [Emotet shutdown](#))

Valid Accounts - T1078

Adversaries may obtain and abuse credentials of existing accounts as a means of gaining Initial Access, Persistence, Privilege Escalation, or Defense Evasion. Compromised credentials may be used to bypass access controls placed on various resources on systems within the network and may even be used for persistent access to remote systems and externally available services, such as VPNs, Outlook Web Access, network devices, and remote desktop. (Citation: [volexity_0day_sophos_FW](#)) Compromised credentials may also grant an adversary increased privilege to specific systems or access to restricted areas of the network. Adversaries may choose not to use malware or tools in conjunction with the legitimate access those credentials provide to make it harder to detect their presence.

In some cases, adversaries may abuse inactive accounts: for example, those belonging to individuals who are no longer part of an organization. Using these accounts may allow the adversary to evade detection, as the original account user will not be present to identify any anomalous activity taking place on their account. (Citation: [CISA MFA PrintNightmare](#))

The overlap of permissions for local, domain, and cloud accounts across a network of systems is of concern because the adversary may be able to pivot across accounts and systems to reach a high level of access (i.e., domain or enterprise administrator) to bypass access controls set within the enterprise.(Citation: TechNet Credential Theft)

Windows Management Instrumentation - T1047

Adversaries may abuse Windows Management Instrumentation (WMI) to execute malicious commands and payloads. WMI is designed for programmers and is the infrastructure for management data and operations on Windows systems.(Citation: WMI 1-3) WMI is an administration feature that provides a uniform environment to access Windows system components.

The WMI service enables both local and remote access, though the latter is facilitated by [Remote Services](#) such as [Distributed Component Object Model](#) and [Windows Remote Management](#).(Citation: WMI 1-3) Remote WMI over DCOM operates using port 135, whereas WMI over WinRM operates over port 5985 when using HTTP and 5986 for HTTPS.(Citation: WMI 1-3) (Citation: Mandiant WMI)

An adversary can use WMI to interact with local and remote systems and use it as a means to execute various behaviors, such as gathering information for [Discovery](#) as well as [Execution](#) of commands and payloads. (Citation: Mandiant WMI) For example, `wmic.exe` can be abused by an adversary to delete shadow copies with the command `wmic.exe Shadowcopy Delete` (i.e., [Inhibit System Recovery](#)).(Citation: WMI 6)

Note: `wmic.exe` is deprecated as of January of 2024, with the WMIC feature being "disabled by default" on Windows 11+. WMIC will be removed from subsequent Windows releases and replaced by [PowerShell](#) as the primary WMI interface.(Citation: WMI 7,8) In addition to PowerShell and tools like `wbemtool.exe`, COM APIs can also be used to programmatically interact with WMI via C++, .NET, VBScript, etc.(Citation: WMI 7,8)

Data from Local System - T1005

Adversaries may search local system sources, such as file systems, configuration files, local databases, virtual machine files, or process memory, to find files of interest and sensitive data prior to Exfiltration.

Adversaries may do this using a [Command and Scripting Interpreter](#), such as `cmd` as well as a [Network Device CLI](#), which have functionality to interact with the file system to gather information.(Citation: show_run_config_cmd_cisco) Adversaries may also use [Automated Collection](#) on the local system.

System Information Discovery - T1082

An adversary may attempt to get detailed information about the operating system and hardware, including version, patches, hotfixes, service packs, and architecture. Adversaries may use this information to shape follow-on behaviors, including whether or not the adversary fully infects the target and/or attempts specific actions. This behavior is distinct from [Local Storage Discovery](#) which is an adversary's discovery of local drive, disks and/or volumes.

Tools such as [Systeminfo](#) can be used to gather detailed system information. If running with privileged access, a breakdown of system data can be gathered through the `systemsetup` configuration tool on macOS. Adversaries may leverage a [Network Device CLI](#) on network devices to gather detailed system information (e.g. `show version`).(Citation: US-CERT-TA18-106A) On ESXi servers, threat actors may gather system

information from various esxcli utilities, such as `system hostname get` and `system version get`.(Citation: CrowdStrike Hypervisor Jackpotting Pt 2 2021)(Citation: Varonis)

Infrastructure as a Service (IaaS) cloud providers such as AWS, GCP, and Azure allow access to instance and virtual machine information via APIs. Successful authenticated API calls can return data such as the operating system platform and status of a particular instance or the model view of a virtual machine.(Citation: Amazon Describe Instance)(Citation: Google Instances Resource)(Citation: Microsoft Virtual Machine API)

[System Information Discovery](#) combined with information gathered from other forms of discovery and reconnaissance can drive payload development and concealment.(Citation: OSX.FairyTale)(Citation: 20 macOS Common Tools and Techniques)

Phishing - T1566

Adversaries may send phishing messages to gain access to victim systems. All forms of phishing are electronically delivered social engineering. Phishing can be targeted, known as spearphishing. In spearphishing, a specific individual, company, or industry will be targeted by the adversary. More generally, adversaries can conduct non-targeted phishing, such as in mass malware spam campaigns.

Adversaries may send victims emails containing malicious attachments or links, typically to execute malicious code on victim systems. Phishing may also be conducted via third-party services, like social media platforms. Phishing may also involve social engineering techniques, such as posing as a trusted source, as well as evasive techniques such as removing or manipulating emails or metadata/headers from compromised accounts being abused to send messages (e.g., [Email Hiding Rules](#)). (Citation: Microsoft OAuth Spam 2022)(Citation: Palo Alto Unit 42 VBA Infostealer 2014) Another way to accomplish this is by [Email Spoofing](#) (Citation: Proofpoint-spoof) the identity of the sender, which can be used to fool both the human recipient as well as automated security tools.(Citation: cyberproof-double-bounce) or by including the intended target as a party to an existing email thread that includes malicious files or links (i.e., "thread hijacking").(Citation: phishing-krebs)

Victims may also receive phishing messages that instruct them to call a phone number where they are directed to visit a malicious URL, download malware,(Citation: sygnia Luna Month)(Citation: CISA Remote Monitoring and Management Software) or install adversary-accessible remote management tools onto their computer (i.e., [User Execution](#)). (Citation: Unit42 Luna Moth)

Masquerading - T1036

Adversaries may attempt to manipulate features of their artifacts to make them appear legitimate or benign to users and/or security tools. Masquerading occurs when the name or location of an object, legitimate or malicious, is manipulated or abused for the sake of evading defenses and observation. This may include manipulating file metadata, tricking users into misidentifying the file type, and giving legitimate task or service names.

Renaming abusable system utilities to evade security monitoring is also a form of [Masquerading](#).(Citation: LOLBAS Main Site)

System Network Connections Discovery - T1049

Adversaries may attempt to get a listing of network connections to or from the compromised system they are currently accessing or from remote systems by querying for information over the network.

An adversary who gains access to a system that is part of a cloud-based environment may map out Virtual Private Clouds or Virtual Networks in order to determine what systems and services are connected. The actions performed are likely the same types of discovery techniques depending on the operating system, but the resulting information may include details about the networked cloud environment relevant to the adversary's goals. Cloud providers may have different ways in which their virtual networks operate.(Citation: Amazon AWS VPC Guide)(Citation: Microsoft Azure Virtual Network Overview)(Citation: Google VPC Overview) Similarly, adversaries who gain access to network devices may also perform similar discovery activities to gather information about connected systems and services.

Utilities and commands that acquire this information include `netstat`, "net use," and "net session" with `Net`. In Mac and Linux, `netstat` and `lsof` can be used to list current connections. `who -a` and `w` can be used to show which users are currently logged in, similar to "net session". Additionally, built-in features native to network devices and `Network Device CLI` may be used (e.g. `show ip sockets`, `show tcp brief`).(Citation: US-CERT-TA18-106A) On ESXi servers, the command `esxi network ip connection list` can be used to list active network connections.(Citation: Sygnia ESXi Ransomware 2025)

Exploit Public-Facing Application - T1190

Adversaries may attempt to exploit a weakness in an Internet-facing host or system to initially access a network. The weakness in the system can be a software bug, a temporary glitch, or a misconfiguration.

Exploited applications are often websites/web servers, but can also include databases (like SQL), standard services (like SMB or SSH), network device administration and management protocols (like SNMP and Smart Install), and any other system with Internet-accessible open sockets.(Citation: NVD CVE-2016-6662)(Citation: CIS Multiple SMB Vulnerabilities)(Citation: US-CERT TA18-106A Network Infrastructure Devices 2018)(Citation: Cisco Blog Legacy Device Attacks)(Citation: NVD CVE-2014-7169) On ESXi infrastructure, adversaries may exploit exposed OpenSLP services; they may alternatively exploit exposed VMware vCenter servers.(Citation: Recorded Future ESXiArgs Ransomware 2023)(Citation: Ars Technica VMWare Code Execution Vulnerability 2021) Depending on the flaw being exploited, this may also involve [Exploitation for Defense Evasion](#) or [Exploitation for Client Execution](#).

If an application is hosted on cloud-based infrastructure and/or is containerized, then exploiting it may lead to compromise of the underlying instance or container. This can allow an adversary a path to access the cloud or container APIs (e.g., via the [Cloud Instance Metadata API](#)), exploit container host access via [Escape to Host](#), or take advantage of weak identity and access management policies.

Adversaries may also exploit edge network infrastructure and related appliances, specifically targeting devices that do not support robust host-based defenses.(Citation: Mandiant Fortinet Zero Day)(Citation: Wired Russia Cyberwar)

For websites and databases, the OWASP top 10 and CWE top 25 highlight the most common web-based vulnerabilities.(Citation: OWASP Top 10)(Citation: CWE top 25)

Transfer Data to Cloud Account - T1537

Adversaries may exfiltrate data by transferring the data, including through sharing/syncing and creating backups of cloud environments, to another cloud account they control on the same service.

A defender who is monitoring for large transfers to outside the cloud environment through normal file transfers or over command and control channels may not be watching for data transfers to another account within the same cloud provider. Such transfers may utilize existing cloud provider APIs and the internal address space of the cloud provider to blend into normal traffic or avoid data transfers over external network interfaces.(Citation: TLDRSec AWS Attacks)

Adversaries may also use cloud-native mechanisms to share victim data with adversary-controlled cloud accounts, such as creating anonymous file sharing links or, in Azure, a shared access signature (SAS) URI. (Citation: Microsoft Azure Storage Shared Access Signature)

Incidents have been observed where adversaries have created backups of cloud instances and transferred them to separate accounts.(Citation: DOJ GRU Indictment Jul 2018)

Obtain Capabilities - T1588

Adversaries may buy and/or steal capabilities that can be used during targeting. Rather than developing their own capabilities in-house, adversaries may purchase, freely download, or steal them. Activities may include the acquisition of malware, software (including licenses), exploits, certificates, and information relating to vulnerabilities. Adversaries may obtain capabilities to support their operations throughout numerous phases of the adversary lifecycle.

In addition to downloading free malware, software, and exploits from the internet, adversaries may purchase these capabilities from third-party entities. Third-party entities can include technology companies that specialize in malware and exploits, criminal marketplaces, or from individuals.(Citation: NationsBuying) (Citation: PegasusCitizenLab)

In addition to purchasing capabilities, adversaries may steal capabilities from third-party entities (including other adversaries). This can include stealing software licenses, malware, SSL/TLS and code-signing certificates, or raiding closed databases of vulnerabilities or exploits.(Citation: DiginotarCompromise)

Remote Desktop Protocol - T1021.001

Adversaries may use [Valid Accounts](#) to log into a computer using the Remote Desktop Protocol (RDP). The adversary may then perform actions as the logged-on user.

Remote desktop is a common feature in operating systems. It allows a user to log into an interactive session with a system desktop graphical user interface on a remote system. Microsoft refers to its implementation of the Remote Desktop Protocol (RDP) as Remote Desktop Services (RDS).(Citation: TechNet Remote Desktop Services)

Adversaries may connect to a remote system over RDP/RDS to expand access if the service is enabled and allows access to accounts with known credentials. Adversaries will likely use Credential Access techniques to acquire credentials to use with RDP. Adversaries may also use RDP in conjunction with the [Accessibility Features](#) or [Terminal Services DLL](#) for Persistence.(Citation: Alperovitch Malware)

Data Encrypted for Impact - T1486

Adversaries may encrypt data on target systems or on large numbers of systems in a network to interrupt availability to system and network resources. They can attempt to render stored data inaccessible by

encrypting files or data on local and remote drives and withholding access to a decryption key. This may be done in order to extract monetary compensation from a victim in exchange for decryption or a decryption key (ransomware) or to render data permanently inaccessible in cases where the key is not saved or transmitted. (Citation: US-CERT Ransomware 2016)(Citation: FireEye WannaCry 2017)(Citation: US-CERT NotPetya 2017) (Citation: US-CERT SamSam 2018)

In the case of ransomware, it is typical that common user files like Office documents, PDFs, images, videos, audio, text, and source code files will be encrypted (and often renamed and/or tagged with specific file markers). Adversaries may need to first employ other behaviors, such as [File and Directory Permissions Modification](#) or [System Shutdown/Reboot](#), in order to unlock and/or gain access to manipulate these files. (Citation: CarbonBlack Conti July 2020) In some cases, adversaries may encrypt critical system files, disk partitions, and the MBR.(Citation: US-CERT NotPetya 2017) Adversaries may also encrypt virtual machines hosted on ESXi or other hypervisors.(Citation: CrowdStrike Hypervisor Jackpotting Pt 2 2021)

To maximize impact on the target organization, malware designed for encrypting data may have worm-like features to propagate across a network by leveraging other attack techniques like [Valid Accounts](#), [OS Credential Dumping](#), and [SMB/Windows Admin Shares](#).(Citation: FireEye WannaCry 2017)(Citation: US-CERT NotPetya 2017) Encryption malware may also leverage [Internal Defacement](#), such as changing victim wallpapers or ESXi server login messages, or otherwise intimidate victims by sending ransom notes or other messages to connected printers (known as "print bombing").(Citation: NHS Digital Egregor Nov 2020) (Citation: Varonis)

In cloud environments, storage objects within compromised accounts may also be encrypted.(Citation: Rhino S3 Ransomware Part 1) For example, in AWS environments, adversaries may leverage services such as AWS's Server-Side Encryption with Customer Provided Keys (SSE-C) to encrypt data.(Citation: Halcyon AWS Ransomware 2025)

Command and Scripting Interpreter - T1059

Adversaries may abuse command and script interpreters to execute commands, scripts, or binaries. These interfaces and languages provide ways of interacting with computer systems and are a common feature across many different platforms. Most systems come with some built-in command-line interface and scripting capabilities, for example, macOS and Linux distributions include some flavor of [Unix Shell](#) while Windows installations include the [Windows Command Shell](#) and [PowerShell](#).

There are also cross-platform interpreters such as [Python](#), as well as those commonly associated with client applications such as [JavaScript](#) and [Visual Basic](#).

Adversaries may abuse these technologies in various ways as a means of executing arbitrary commands. Commands and scripts can be embedded in [Initial Access](#) payloads delivered to victims as lure documents or as secondary payloads downloaded from an existing C2. Adversaries may also execute commands through interactive terminals/shells, as well as utilize various [Remote Services](#) in order to achieve remote Execution. (Citation: Powershell Remote Commands)(Citation: Cisco IOS Software Integrity Assurance - Command History)(Citation: Remote Shell Execution in Python)

Service Execution - T1569.002

Adversaries may abuse the Windows service control manager to execute malicious commands or payloads. The Windows service control manager ([services.exe](#)) is an interface to manage and manipulate services.

(Citation: Microsoft Service Control Manager) The service control manager is accessible to users via GUI components as well as system utilities such as `sc.exe` and `Net`.

`PsExec` can also be used to execute commands or payloads via a temporary Windows service created through the service control manager API.(Citation: Russinovich Sysinternals) Tools such as `PsExec` and `sc.exe` can accept remote servers as arguments and may be used to conduct remote execution.

Adversaries may leverage these mechanisms to execute malicious content. This can be done by either executing a new or modified service. This technique is the execution used in conjunction with `Windows Service` during service persistence or privilege escalation.

Domain Account - T1087.002

Adversaries may attempt to get a listing of domain accounts. This information can help adversaries determine which domain accounts exist to aid in follow-on behavior such as targeting specific accounts which possess particular privileges.

Commands such as `net user /domain` and `net group /domain` of the `Net` utility, `dscacheutil -q group` on macOS, and `ldapsearch` on Linux can list domain users and groups. `PowerShell` cmdlets including `Get-ADUser` and `Get-ADGroupMember` may enumerate members of Active Directory groups.(Citation: CrowdStrike StellarParticle January 2022)

System Services - T1569

Adversaries may abuse system services or daemons to execute commands or programs. Adversaries can execute malicious content by interacting with or creating services either locally or remotely. Many services are set to run at boot, which can aid in achieving persistence (`Create or Modify System Process`), but adversaries can also abuse services for one-time or temporary execution.

Application Layer Protocol - T1071

Adversaries may communicate using OSI application layer protocols to avoid detection/network filtering by blending in with existing traffic. Commands to the remote system, and often the results of those commands, will be embedded within the protocol traffic between the client and server.

Adversaries may utilize many different protocols, including those used for web browsing, transferring files, electronic mail, DNS, or publishing/subscribing. For connections that occur internally within an enclave (such as those between a proxy or pivot node and other nodes), commonly used protocols are SMB, SSH, or RDP. (Citation: Mandiant APT29 Eye Spy Email Nov 22)

Permission Groups Discovery - T1069

Adversaries may attempt to discover group and permission settings. This information can help adversaries determine which user accounts and groups are available, the membership of users in particular groups, and which users and groups have elevated permissions.

Adversaries may attempt to discover group permission settings in many different ways. This data may provide the adversary with information about the compromised environment that can be used in follow-on activity and targeting.(Citation: CrowdStrike BloodHound April 2018)

Domain Groups - T1069.002

Adversaries may attempt to find domain-level groups and permission settings. The knowledge of domain-level permission groups can help adversaries determine which groups exist and which users belong to a particular group. Adversaries may use this information to determine which users have elevated permissions, such as domain administrators.

Commands such as `net group /domain` of the [Net](#) utility, `dscacheutil -q group` on macOS, and `ldapsearch` on Linux can list domain-level groups.

File and Directory Discovery - T1083

Adversaries may enumerate files and directories or may search in specific locations of a host or network share for certain information within a file system. Adversaries may use the information from [File and Directory Discovery](#) during automated discovery to shape follow-on behaviors, including whether or not the adversary fully infects the target and/or attempts specific actions.

Many command shell utilities can be used to obtain this information. Examples include `dir`, `tree`, `ls`, `find`, and `locate`.(Citation: Windows Commands JPCERT) Custom tools may also be used to gather file and directory information and interact with the [Native API](#). Adversaries may also leverage a [Network Device CLI](#) on network devices to gather file and directory information (e.g. `dir`, `show flash`, and/or `nvr`am).(Citation: US-CERT-TA18-106A)

Some files and directories may require elevated or specific user permissions to access.

Ingress Tool Transfer - T1105

Adversaries may transfer tools or other files from an external system into a compromised environment. Tools or files may be copied from an external adversary-controlled system to the victim network through the command and control channel or through alternate protocols such as `ftp`. Once present, adversaries may also transfer/spread tools between victim devices within a compromised environment (i.e. [Lateral Tool Transfer](#)).

On Windows, adversaries may use various utilities to download tools, such as `copy`, `finger`, `certutil`, and `PowerShell` commands such as `IEX(New-Object Net.WebClient).downloadString()` and `Invoke-WebRequest`. On Linux and macOS systems, a variety of utilities also exist, such as `curl`, `scp`, `sftp`, `tftp`, `rsync`, `finger`, and `wget`.(Citation: t1105_Iolbas) A number of these tools, such as `wget`, `curl`, and `scp`, also exist on ESXi. After downloading a file, a threat actor may attempt to verify its integrity by checking its hash value (e.g., via `certutil -hashfile`).(Citation: Google Cloud Threat Intelligence COSCMICENERGY 2023)

Adversaries may also abuse installers and package managers, such as `yum` or `winget`, to download tools to victim hosts. Adversaries have also abused file application features, such as the Windows `search-ms` protocol handler, to deliver malicious files to victims through remote file searches invoked by [User Execution](#) (typically after interacting with [Phishing](#) lures).(Citation: T1105: Trellix_search-ms)

Files can also be transferred using various [Web Services](#) as well as native or otherwise present tools on the victim system.(Citation: PTSecurity Cobalt Dec 2016) In some cases, adversaries may be able to leverage services that sync between a web-based and an on-premises client, such as Dropbox or OneDrive, to transfer files onto victim systems. For example, by compromising a cloud account and logging into the service's web

portal, an adversary may be able to trigger an automatic syncing process that transfers the file onto the victim's machine.(Citation: Dropbox Malware Sync)

Financial Theft - T1657

Adversaries may steal monetary resources from targets through extortion, social engineering, technical theft, or other methods aimed at their own financial gain at the expense of the availability of these resources for victims. Financial theft is the ultimate objective of several popular campaign types including extortion by ransomware,(Citation: FBI-ransomware) business email compromise (BEC) and fraud,(Citation: FBI-BEC) "pig butchering,"(Citation: wired-pig butchering) bank hacking,(Citation: DOJ-DPRK Heist) and exploiting cryptocurrency networks.(Citation: BBC-Ronin)

Adversaries may [Compromise Accounts](#) to conduct unauthorized transfers of funds.(Citation: Internet crime report 2022) In the case of business email compromise or email fraud, an adversary may utilize [Impersonation](#) of a trusted entity. Once the social engineering is successful, victims can be deceived into sending money to financial accounts controlled by an adversary.(Citation: FBI-BEC) This creates the potential for multiple victims (i.e., compromised accounts as well as the ultimate monetary loss) in incidents involving financial theft. (Citation: VEC)

Extortion by ransomware may occur, for example, when an adversary demands payment from a victim after [Data Encrypted for Impact](#) (Citation: NYT-Colonial) and [Exfiltration](#) of data, followed by threatening to leak sensitive data to the public unless payment is made to the adversary.(Citation: Mandiant-leaks) Adversaries may use dedicated leak sites to distribute victim data.(Citation: Crowdstrike-leaks)

Due to the potentially immense business impact of financial theft, an adversary may abuse the possibility of financial theft and seeking monetary gain to divert attention from their true goals such as [Data Destruction](#) and business disruption.(Citation: AP-NotPetya)

Tool - T1588.002

Adversaries may buy, steal, or download software tools that can be used during targeting. Tools can be open or closed source, free or commercial. A tool can be used for malicious purposes by an adversary, but (unlike malware) were not intended to be used for those purposes (ex: [PsExec](#)).

Adversaries may obtain tools to support their operations, including to support execution of post-compromise behaviors. Tools may also be leveraged for testing – for example, evaluating malware against commercial antivirus or endpoint detection and response (EDR) applications.(Citation: Forescout Conti Leaks 2022) (Citation: Sentinel Labs Top Tier Target 2025)

Tool acquisition may involve the procurement of commercial software licenses, including for red teaming tools such as Cobalt Strike. In addition to freely downloading or purchasing software, adversaries may steal software and/or software licenses from third-party entities (including other adversaries). Threat actors may also crack trial versions of software.(Citation: Recorded Future Beacon 2019)

Network Share Discovery - T1135

Adversaries may look for folders and drives shared on remote systems as a means of identifying sources of information to gather as a precursor for Collection and to identify potential systems of interest for Lateral

Movement. Networks often contain shared network drives and folders that enable users to access file directories on various systems across a network.

File sharing over a Windows network occurs over the SMB protocol. (Citation: Wikipedia Shared Resource) (Citation: TechNet Shared Folder) `Net` can be used to query a remote system for available shared drives using the `net view \\\\remotesystem` command. It can also be used to query shared drives on the local system using `net share`. For macOS, the `sharing -l` command lists all shared points used for smb services.

Disable or Modify Tools - T1562.001

Adversaries may modify and/or disable security tools to avoid possible detection of their malware/tools and activities. This may take many forms, such as killing security software processes or services, modifying / deleting Registry keys or configuration files so that tools do not operate properly, or other methods to interfere with security tools scanning or reporting information. Adversaries may also disable updates to prevent the latest security patches from reaching tools on victim systems.(Citation: SCADAfence_ransomware)

Adversaries may trigger a denial-of-service attack via legitimate system processes. It has been previously observed that the Windows Time Travel Debugging (TTD) monitor driver can be used to initiate a debugging session for a security tool (e.g., an EDR) and render the tool non-functional. By hooking the debugger into the EDR process, all child processes from the EDR will be automatically suspended. The attacker can terminate any EDR helper processes (unprotected by Windows Protected Process Light) by abusing the Process Explorer driver. In combination this will halt any attempt to restart services and cause the tool to crash.(Citation: Cocomazzi FIN7 Reboot)

Adversaries may also tamper with artifacts deployed and utilized by security tools. Security tools may make dynamic changes to system components in order to maintain visibility into specific events. For example, security products may load their own modules and/or modify those loaded by processes to facilitate data collection. Similar to [Indicator Blocking](#), adversaries may unhook or otherwise modify these features added by tools (especially those that exist in userland or are otherwise potentially accessible to adversaries) to avoid detection.(Citation: OutFlank System Calls)(Citation: MDSec System Calls) For example, adversaries may abuse the Windows process mitigation policy to block certain endpoint detection and response (EDR) products from loading their user-mode code via DLLs. By spawning a process with the `PROCESS_CREATION_MITIGATION_POLICY_BLOCK_NON_MICROSOFT_BINARIES_ALWAYS_ON` attribute using API calls like `UpdateProcThreadAttribute`, adversaries may evade detection by endpoint security solutions that rely on DLLs that are not signed by Microsoft. Alternatively, they may add new directories to an EDR tool's exclusion list, enabling them to hide malicious files via [File/Path Exclusions](#).(Citation: BlackBerry WhisperGate 2022)(Citation: Google Cloud Threat Intelligence FIN13 2021)

Adversaries may also focus on specific applications such as Sysmon. For example, the "Start" and "Enable" values in `HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\WMI\AutoLogger\EventLog-Microsoft-Windows-Sysmon-Operational` may be modified to tamper with and potentially disable Sysmon logging.(Citation: disable_win_evt_logging)

On network devices, adversaries may attempt to skip digital signature verification checks by altering startup configuration files and effectively disabling firmware verification that typically occurs at boot.(Citation: Fortinet Zero-Day and Custom Malware Used by Suspected Chinese Actor in Espionage Operation)(Citation: Analysis of FG-IR-22-369)

In cloud environments, tools disabled by adversaries may include cloud monitoring agents that report back to services such as AWS CloudWatch or Google Cloud Monitor.

Furthermore, although defensive tools may have anti-tampering mechanisms, adversaries may abuse tools such as legitimate rootkit removal kits to impair and/or disable these tools.(Citation: chasing_avaddon_ransomware)(Citation: dharma_ransomware)(Citation: demystifying_ryuk)(Citation: doppelpaymer_crowdstrike) For example, adversaries have used tools such as GMER to find and shut down hidden processes and antivirus software on infected systems.(Citation: demystifying_ryuk)

Additionally, adversaries may exploit legitimate drivers from anti-virus software to gain access to kernel space (i.e. [Exploitation for Privilege Escalation](#)), which may lead to bypassing anti-tampering features.(Citation: avoslocker_ransomware)

Exfiltration Over Alternative Protocol - T1048

Adversaries may steal data by exfiltrating it over a different protocol than that of the existing command and control channel. The data may also be sent to an alternate network location from the main command and control server.

Alternate protocols include FTP, SMTP, HTTP/S, DNS, SMB, or any other network protocol not being used as the main command and control channel. Adversaries may also opt to encrypt and/or obfuscate these alternate channels.

[Exfiltration Over Alternative Protocol](#) can be done using various common operating system utilities such as [Net/SMB](#) or FTP.(Citation: Palo Alto OilRig Oct 2016) On macOS and Linux [curl](#) may be used to invoke protocols such as HTTP/S or FTP/S to exfiltrate data from a system.(Citation: 20 macOS Common Tools and Techniques)

Many IaaS and SaaS platforms (such as Microsoft Exchange, Microsoft SharePoint, GitHub, and AWS S3) support the direct download of files, emails, source code, and other sensitive information via the web console or [Cloud API](#).